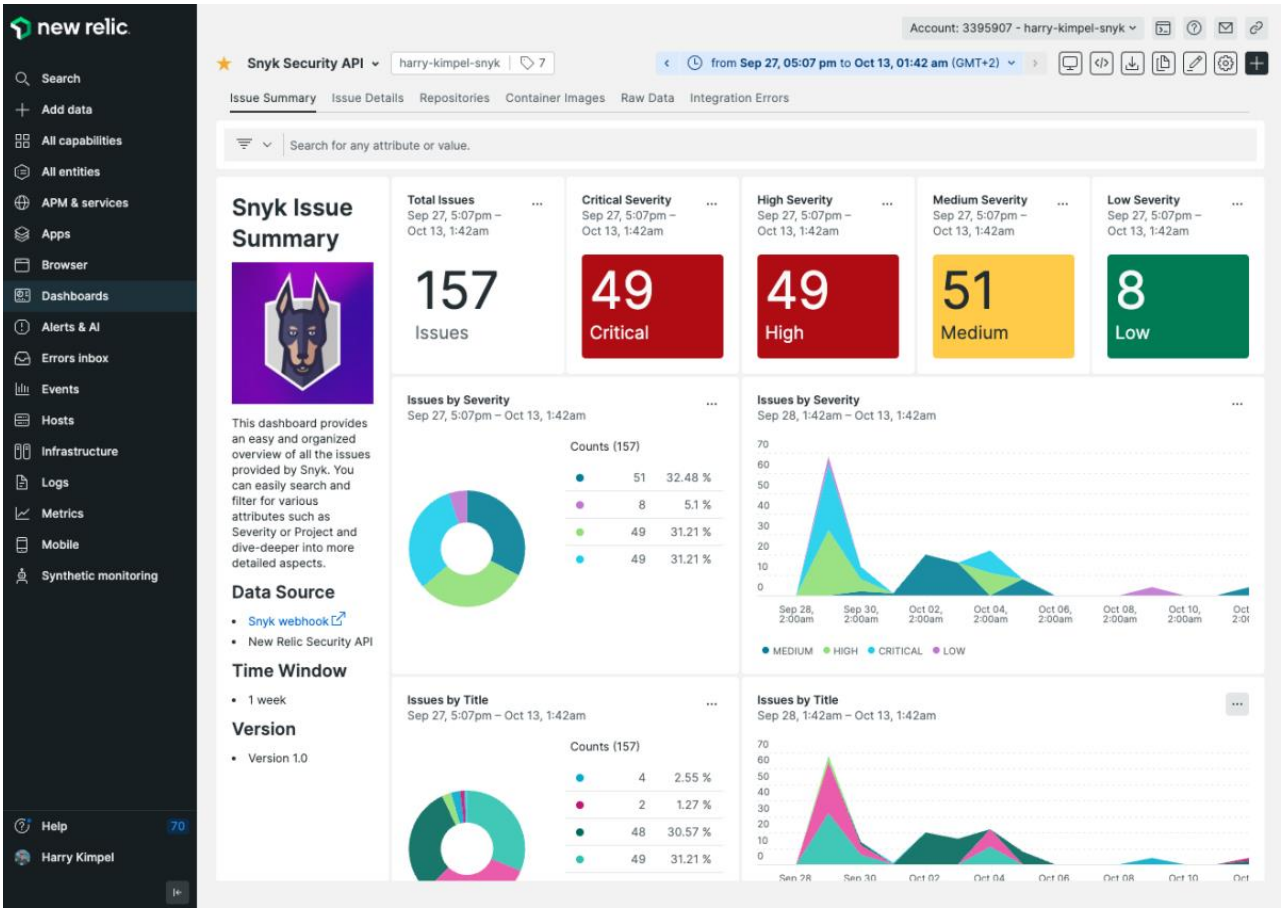
3.2 Ferramenta Snyk



Objetivo principal

A Snyk auxilia os desenvolvedores a encontrar problemas de segurança de forma automática, verificando isso desde o início da codificação, em vez de deixar isso para o final do ciclo de vida do software, garantindo que bibliotecas, contêineres, aplicações e arquivos de configuração de infraestrutura sejam seguros. As recomendações de correção automáticas são precisas para as vulnerabilidades encontradas.

Tipo de análise que realiza

A Snyk realiza análise estática, principalmente porque utiliza o SAST, que analisa o código fonte sem executá-lo, buscando problemas logo enquanto o desenvolvedor escreve o código.

Quais artefatos ou informações consegue extrair

As principais informações extraídas são: dependências de código aberto, como conformidade legal de bibliotecas e suas vulnerabilidades; análise do código fonte, como falhas de segurança na IDE ou no repositório; contêineres e imagens, analisando camadas de imagem de container; e configurações de infraestrutura, com o IAC, identificando erros que podem expor a infraestrutura em nuvem.

Que tipo de apoio oferece à reengenharia

A ferramenta apoia a reengenharia com sua detecção e correção automática de problemas no código próprio ou em bibliotecas, oferecendo melhorias autofix para bibliotecas desatualizadas ou vulneráveis em aplicações legadas. Além de facilitar imigrações para contêineres ao analisar imagens, modernizando a infraestrutura. E ainda garante que o novo código da reegenharia já nasça seguro devido ao shift left, que move a segurança para o início do ciclo de desenvolvimento.

Vantagens

As principais vantagens são: correção automática, reduzindo o tempo de remediação; priorização de riscos, analisando quais vulnerabilidades devem ser corrigidas primeiro com base no risco que apresentam; trata a segurança como parte do fluxo diário do desenvolvimento; análise abrangente, desde código aberto, conteiners, infraestrutura como código e SAST.

Limitações

As principais limitações são: restrições severas no plano gratuito, como número de testes pequenos; falsos positivos no encontro de vulnerabilidades; complexidade na correção automática, que embora seja uma vantagem em ter ela, a mesma também pode quebrar dependências de projetos em atualizações automáticas de pacotes, exigindo análise humana para algumas coisas;